

00:00:02,489 --> 00:00:22,060 [speaker_0]

Perfect. So, as I already mentioned, like, my research is, [sighs] uh, or the idea is, um, that like a lot of software development teams, they get, like, too confident in using-

00:00:22,080 --> 00:00:22,460 [speaker_1]

Mm

00:00:22,660 --> 00:00:31,000 [speaker_0]

... AI and coding with AI, and, like, the whole autocompletion thing, or even, like, setting up whole code bases just with AI.

00:00:31,010 --> 00:00:31,010 [speaker_1]

Yeah.

00:00:31,120 --> 00:00:39,060 [speaker_0]

Um, and so the idea is how to kind of audit, um, this process in using-

00:00:39,080 --> 00:00:39,240 [speaker_1]

Mm

00:00:39,460 --> 00:00:42,030 [speaker_0]

... uh, generative AI in, in software development.

00:00:42,060 --> 00:00:42,560 [speaker_1]

Mm-hmm.

00:00:42,720 --> 00:00:57,340 [speaker_0]

So I developed, um, a prototype, um, where the new generated codes is, like, tested against vulnerabilities and searches for, for vulnerability findings, similar to his research, actually-

00:00:57,640 --> 00:00:57,650 [speaker_1]

Mm

00:00:57,650 --> 00:01:16,560 [speaker_0]

... um, like with the whole static analysis tools. Um, and then at the end of the, of the, of the pipeline, a report is generated. Um, I would say, yeah, for like risk managers or for audit purposes, like when a third-party audit-

00:01:16,570 --> 00:01:16,570 [speaker_1]

Mm

00:01:16,570 --> 00:01:28,620 [speaker_0]

... auditor comes to the software development companies, so they can prove, like, "We have this process, and they, here are our reports that we generated, and we have these vulnerabilities and how we mitigated them-"

00:01:28,640 --> 00:01:28,810 [speaker_1]

Mm.

00:01:28,820 --> 00:02:01,320 [speaker_0]

"... and all that stuff." Um, and with the interviews that I'm doing, I kind of just, [exhales] I want to establish a baseline what industry experts, uh, think is necessary to include in those reports, or what is, like, too much information, or I think maybe you, you already go- uh, got the point.

So my, my questions are not technical in any way. It's just, um, yeah, on the regulatory side.

00:02:01,360 --> 00:02:02,080 [speaker_1]

Yeah.

00:02:02,180 --> 00:02:02,900 [speaker_0]

And-

00:02:02,980 --> 00:02:03,760 [speaker_1]

So just checking-

00:02:03,780 --> 00:02:04,140 [speaker_0]

[clears throat]

00:02:04,900 --> 00:02:08,580 [speaker_1]

... the, the reports are the reports that the auditors write, or the reports are-

00:02:08,590 --> 00:02:12,140 [speaker_0]

Uh, so no, my tool, my tool generates, uh, the, those reports.

00:02:12,160 --> 00:02:13,060 [speaker_1]

Ah, yeah.

00:02:13,080 --> 00:02:14,300 [speaker_0]

And the audience is-

00:02:14,310 --> 00:02:14,310 [speaker_1]

Right

00:02:14,310 --> 00:02:15,400 [speaker_0]

... like, for-

00:02:15,420 --> 00:02:15,600 [speaker_1]

Yeah

00:02:15,640 --> 00:02:19,340 [speaker_0]

... risk managers or auditors or, or something. So, um, also the-

00:02:19,360 --> 00:02:19,370 [speaker_1]

Right

00:02:19,370 --> 00:02:24,380 [speaker_0]

... the report shouldn't, like, be too technical because then they won't understand it.

00:02:24,390 --> 00:02:24,390 [speaker_1]

Yeah.

00:02:24,400 --> 00:02:30,820 [speaker_0]

But all the necessary information should be included, like, where's the sweet spot? Um-

00:02:30,860 --> 00:02:31,720 [speaker_1]

Yes.

00:02:31,760 --> 00:02:32,460 [speaker_0]

Yeah, that's-

00:02:32,470 --> 00:02:34,760 [speaker_1]

And so essentially like an automated auditor.

00:02:34,820 --> 00:02:35,840 [speaker_0]

Right. Yeah.

00:02:35,860 --> 00:02:36,040 [speaker_1]

Yeah.

00:02:36,080 --> 00:02:38,040 [speaker_0]

Exactly. That's the-

00:02:38,049 --> 00:02:38,049 [speaker_1]

Okay

00:02:38,049 --> 00:02:39,250 [speaker_0]

... that's the goal. [chuckles]

00:02:39,250 --> 00:02:39,400 [speaker_1]

Yeah.

00:02:39,800 --> 00:02:43,210 [speaker_0]

Includes a lot of magic, and like, it's only a, a proof of concept, basically.

00:02:43,210 --> 00:02:43,910 [speaker_1]

Yeah.

00:02:44,020 --> 00:02:48,180 [speaker_0]

Um, for now, it serves its, its purpose.

00:02:48,190 --> 00:02:48,190 [speaker_1]

Yeah.

00:02:48,300 --> 00:02:56,380 [speaker_0]

Um, I only have seven questions. Um, and also I wanted to mention, if there's, like, a question where you say-

00:02:56,420 --> 00:02:56,480 [speaker_1]

Mm

00:02:57,040 --> 00:02:58,829 [speaker_0]

... "I have no idea what he wants from me" [chuckles]

00:02:58,829 --> 00:02:58,850 [speaker_1]

[chuckles]

00:02:58,850 --> 00:03:32,660 [speaker_0]

... or what the question is aiming for, like, don't hesitate at all. Um, just tell me. We can skip any question. That's, uh, nothing we should worry about. All right, um, the first question, um, is: When you hear audit-ready security report, like this made-up term, um, in your perspective, what should it contain, um, to accept, accept it as reliable or even, like, meets the definition of

an audit report-

00:03:32,670 --> 00:03:32,670 [speaker_1]

Mm

00:03:32,670 --> 00:03:39,520 [speaker_0]

... in regards to security? Or what would be a deal breaker if it were missing, like, when there's no vulnerabilities in the report-

00:03:39,560 --> 00:03:39,570 [speaker_1]

Mm

00:03:39,570 --> 00:03:41,840 [speaker_0]

... then it makes no sense, or-

00:03:41,860 --> 00:03:41,870 [speaker_1]

Mm

00:03:41,870 --> 00:03:45,290 [speaker_0]

... like, what are your fir- first thoughts about that? [chuckles]

00:03:45,320 --> 00:03:48,860 [speaker_1]

Yeah. Uh, okay, so I won't be very technical, but-

00:03:48,960 --> 00:03:49,090 [speaker_0]

Yeah

00:03:49,120 --> 00:03:49,400 [speaker_1]

... like-

00:03:49,520 --> 00:03:49,690 [speaker_0]

Sure

00:03:50,180 --> 00:03:56,880 [speaker_1]

... I would, so yeah, I would want to see, like, scope. Like, what was evaluated, like, which, like, systems-

00:03:56,900 --> 00:03:56,910 [speaker_0]

Mm-hmm

00:03:56,940 --> 00:04:11,570 [speaker_1]

... um, which sort of, uh... But also, like, w- did, w- like, yeah, like, sort of what's the scope of the system? So were, like, organizational practices taken into account as well, for example?

00:04:11,580 --> 00:04:11,740 [speaker_0]

Mm-hmm.

00:04:11,800 --> 00:04:17,120 [speaker_1]

Things like, um, whether the company has, like, a human-in-the-loop process or not-

00:04:17,160 --> 00:04:17,190 [speaker_0]

Mm-hmm

00:04:17,959 --> 00:04:33,850 [speaker_1]

... um, things like that. So, so what is, what is the scope of the, of the, of the system, and which components were taken into account, which processes? And then, um, yeah, I mean, I guess like, um, any vulnerabilities found-

00:04:33,880 --> 00:04:33,910 [speaker_0]

Mm-hmm

00:04:34,080 --> 00:04:39,700 [speaker_1]

... um, and sort of an assessment maybe of the severities.

00:04:39,720 --> 00:04:39,730 [speaker_0]

Mm-hmm.

00:04:39,730 --> 00:04:53,450 [speaker_1]

Uh, severity of each of them. Um, then another one is, like, how much-- Sort of like the whole methodology, right?

00:04:53,740 --> 00:04:53,880 [speaker_0]

Mm-hmm.

00:04:53,920 --> 00:04:55,640 [speaker_1]

Like, what's the, what's the setup?

00:04:55,660 --> 00:04:59,620 [speaker_0]

Mm-hmm. Mm-hmm. Mm-hmm.

00:04:59,920 --> 00:05:14,540 [speaker_1]

And how much, like, time, budget, and, like, compute budget and whatnot was spent. And then regarding all of these, like, possible, like, limitations, like, conclusions and, and limitations that can be drawn.

00:05:15,060 --> 00:05:15,250 [speaker_0]

Mm-hmm.

00:05:15,250 --> 00:05:24,469 [speaker_1]

Um, and maybe also, like, an overall, some, some sort of, like, overall rating or something that like-

00:05:24,480 --> 00:05:24,590 [speaker_0]

Mm-hmm

00:05:24,590 --> 00:05:30,050 [speaker_1]

... a score or recommendation that is something like tying this all together, [chuckles] like-

00:05:30,100 --> 00:05:31,300 [speaker_0]

Mm-hmm. Perfect.

00:05:31,380 --> 00:05:33,790 [speaker_1]

I think this is like...

00:05:34,000 --> 00:05:34,180 [speaker_0]

Yeah.

00:05:34,190 --> 00:05:39,720 [speaker_1]

Like, this system is, like, safe for use in, like, non-- like, like, in-

00:05:39,760 --> 00:05:40,140 [speaker_0]

I see, yeah

00:05:40,300 --> 00:05:41,640 [speaker_1]

... in, like, this and that-

00:05:41,660 --> 00:05:41,880 [speaker_0]

Mm-hmm

00:05:42,080 --> 00:05:42,350 [speaker_1]

... um, way.

00:05:42,460 --> 00:05:43,050 [speaker_0]

Context, yeah.

00:05:43,050 --> 00:05:46,220 [speaker_1]

Or, like, safe against, like, these and those, like, threat actors.

00:05:46,260 --> 00:05:46,500 [speaker_0]

Yeah.

00:05:46,620 --> 00:05:49,280 [speaker_1]

Um, or, or not.

00:05:49,300 --> 00:05:50,020 [speaker_0]

Mm-hmm.

00:05:50,060 --> 00:05:51,400 [speaker_1]

Something like that.

00:05:51,540 --> 00:06:00,140 [speaker_0]

You said a lot of, um, important things. Actually, in-- at the end, I will, uh, show you a mock report that I generated.

00:06:00,180 --> 00:06:00,910 [speaker_1]

Mm.

00:06:00,910 --> 00:06:04,400 [speaker_0]

And, like, eighty percent of the things you said are already included, so that's great.

00:06:04,760 --> 00:06:04,820 [speaker_1]

[chuckles]

00:06:05,244 --> 00:06:17,304 [speaker_0]

... Um, yeah. So, uh, the second question is, um, what kind of evidence makes statements about security credible to you, and what does not? Like-

00:06:17,384 --> 00:06:17,394 [speaker_1]

Mm

00:06:17,394 --> 00:06:22,623 [speaker_0]

... measurements, um, or policies that the company complies with or-

00:06:22,844 --> 00:06:23,104 [speaker_1]

Yeah

00:06:23,114 --> 00:06:25,144 [speaker_0]

... I don't know, responsibilities and-

00:06:25,744 --> 00:06:25,834 [speaker_1]

Yeah

00:06:25,864 --> 00:06:28,123 [speaker_0]

... all that stuff.

00:06:28,264 --> 00:06:39,323 [speaker_1]

Um, yeah. So it does help if common-- Like, I-- So first, yeah, if commonly v- referenced frameworks are used.

00:06:39,804 --> 00:06:40,464 [speaker_0]

Mm-hmm.

00:06:40,474 --> 00:06:53,534 [speaker_1]

Um, like MITRE ATT&CK or, um... Yeah, some, uh, like if there's like, for example, like a published benchmark that everyone uses or something like that.

00:06:53,544 --> 00:06:55,844 [speaker_0]

Mm-hmm. Yep.

00:06:55,884 --> 00:07:13,104 [speaker_1]

Um, and then there's a reference to that framework, that helps. Um, it also helps-- I mean, this is a bit beyond like the individual evaluation. It's more like if there is a lot of information about this particular system process methodology that is employed, if like a lot of information about that is public and-

00:07:13,123 --> 00:07:13,344 [speaker_0]

Mm-hmm

00:07:13,544 --> 00:07:17,384 [speaker_1]

... like, like there's like some discourse, um-

00:07:17,404 --> 00:07:18,323 [speaker_0]

Mm.

00:07:18,384 --> 00:07:24,884 [speaker_1]

And, and sort of I can see, okay, this is like a generally, uh-- like, like people in general seem to take this methodology-

00:07:24,904 --> 00:07:24,954 [speaker_0]

Yep

00:07:25,164 --> 00:07:45,063 [speaker_1]

... seriously or something like that. And then, like, particular information, um... Yeah, usually, I mean, for, for, for like a sort of, I, I-- probably the closest I am to something like my closest role

is like, I'm just like decision maker. Like, I get information-

00:07:45,144 --> 00:07:45,183 [speaker_0]

Mm

00:07:45,193 --> 00:07:47,823 [speaker_1]

... I'm like not super, like into the de- details.

00:07:47,844 --> 00:07:48,224 [speaker_0]

Mm-hmm.

00:07:48,244 --> 00:07:59,044 [speaker_1]

But like, and, and it's like if there's some sort of, uh, coherent and, like, well-explained methodology that's like-

00:07:59,084 --> 00:07:59,274 [speaker_0]

Mm-hmm

00:07:59,284 --> 00:08:00,344 [speaker_1]

... "Here's what we did-"

00:08:00,364 --> 00:08:00,594 [speaker_0]

Mm-hmm

00:08:00,604 --> 00:08:11,063 [speaker_1]

"... and here's what this means." Um, or like, "So here's why we do this, and then here's the results, here's what this means. Um, here are the limitations," like essentially the stuff you said earlier.

00:08:11,084 --> 00:08:12,264 [speaker_0]

Mm-hmm.

00:08:12,384 --> 00:08:26,144 [speaker_1]

Um, then, then that's good. Um, yeah, but generally, I would rely a lot on... Like, I personally would find it hard to just like-

00:08:26,203 --> 00:08:26,244 [speaker_0]

[clears throat]

00:08:26,254 --> 00:08:31,664 [speaker_1]

... based on like, like sort of, sort of like a single, like evaluation or like audit or like-

00:08:31,703 --> 00:08:31,833 [speaker_0]

Mm-hmm

00:08:31,943 --> 00:08:38,583 [speaker_1]

... get information and, and like be like, "Okay, this is well done or not." Um, then like I, I need like a, like someone-

00:08:38,604 --> 00:08:38,614 [speaker_0]

Mm-hmm

00:08:38,764 --> 00:08:39,963 [speaker_1]

... with like security background-

00:08:40,044 --> 00:08:40,683 [speaker_0]

Mm-hmm, mm-hmm

00:08:40,703 --> 00:08:41,924 [speaker_1]

... to, to, to give me like-

00:08:41,943 --> 00:08:42,124 [speaker_0]

I see

00:08:42,244 --> 00:08:48,014 [speaker_1]

... yeah, an assessment. Um, so I can either do that, like have someone with security knowledge and tell me-

00:08:48,084 --> 00:08:48,114 [speaker_0]

Mm-hmm

00:08:48,114 --> 00:08:49,223 [speaker_1]

... is this solid or not?

00:08:49,284 --> 00:08:49,454 [speaker_0]

Mm-hmm.

00:08:49,983 --> 00:08:55,824 [speaker_1]

Or, yeah, or do this thing of like, uh, Google essentially. "Okay, like, do people generally-

00:08:55,904 --> 00:08:56,074 [speaker_0]

Yeah.

00:08:56,074 --> 00:08:57,684 [speaker_1]

... think this is a good, good thing?

00:08:57,704 --> 00:08:57,814 [speaker_0]

Yeah.

00:08:57,884 --> 00:09:04,294 [speaker_1]

Do people rely on this?" Um, and yeah.

00:09:04,304 --> 00:09:05,744 [speaker_0]

What about measurements?

00:09:05,983 --> 00:09:06,814 [speaker_1]

Mm-hmm.

00:09:06,814 --> 00:09:17,284 [speaker_0]

Um, would that be helpful, like, to see, I don't know, um, a vulnerability density across the code base or like findings per-

00:09:17,304 --> 00:09:17,314 [speaker_1]

Yeah

00:09:17,314 --> 00:09:19,804 [speaker_0]

... thousand lines of code? Or is that-

00:09:20,404 --> 00:09:20,414 [speaker_1]

So-

00:09:20,444 --> 00:09:21,624 [speaker_0]

... too, too much to-

00:09:21,684 --> 00:09:22,524 [speaker_1]

It's too detailed-

00:09:22,544 --> 00:09:22,614 [speaker_0]

I don't know

00:09:22,614 --> 00:09:22,944 [speaker_1]

... in a way-

00:09:22,983 --> 00:09:23,074 [speaker_0]

Yeah

00:09:23,084 --> 00:09:25,304 [speaker_1]

... because like I'm not-- I don't know what [coughs] it means.

00:09:25,464 --> 00:09:25,664 [speaker_0]

Okay.

00:09:25,684 --> 00:09:26,144 [speaker_1]

I think it would-

00:09:26,164 --> 00:09:26,174 [speaker_0]

Yeah

00:09:26,174 --> 00:09:29,964 [speaker_1]

... it is useful if there's a comparison, so it needs to be contextualized for me.

00:09:29,973 --> 00:09:30,144 [speaker_0]

Mm. Yeah.

00:09:30,164 --> 00:09:36,384 [speaker_1]

So if it was like compared to, like... So one thing is like trends.

00:09:36,404 --> 00:09:36,944 [speaker_0]

Mm-hmm.

00:09:37,004 --> 00:09:39,164 [speaker_1]

On like, okay, this is like what the previous model-

00:09:39,184 --> 00:09:39,194 [speaker_0]

Yep

00:09:39,194 --> 00:09:43,444 [speaker_1]

... that we deployed, um, like, like what the previous system-

00:09:43,514 --> 00:09:43,594 [speaker_0]

Mm

00:09:43,644 --> 00:09:46,604 [speaker_1]

... or like how it looked like for that system, and in general, like-

00:09:46,644 --> 00:09:46,794 [speaker_0]

Yep

00:09:46,794 --> 00:09:51,404 [speaker_1]

... you're like: Okay, and then for that system, everything went fine, so maybe now if like we have a similar-

00:09:51,444 --> 00:09:51,504 [speaker_0]

Mm

00:09:51,514 --> 00:09:57,024 [speaker_1]

... so it's like fine as well. Or a comparison, like, here's what's typical in this-

00:09:57,044 --> 00:09:57,164 [speaker_0]

Yep

00:09:57,174 --> 00:09:57,904 [speaker_1]

... industry.

00:09:57,924 --> 00:09:58,184 [speaker_0]

Yep.

00:09:58,204 --> 00:10:01,174 [speaker_1]

Or here's what's typical for, like, big tech or like Google App-

00:10:01,184 --> 00:10:01,233 [speaker_0]

Mm

00:10:01,284 --> 00:10:02,324 [speaker_1]

... or like, here's what's typical for-

00:10:02,424 --> 00:10:02,604 [speaker_0]

Mm

00:10:02,764 --> 00:10:06,654 [speaker_1]

... research labs, like what their security looks like. Some sort of-

00:10:06,664 --> 00:10:06,754 [speaker_0]

Yeah

00:10:06,754 --> 00:10:07,834 [speaker_1]

... contextualization.

00:10:07,884 --> 00:10:25,024 [speaker_0]

Yeah, that's great. That's a great hint. Perfect. Um, I think we covered question three pretty much. It was how much context is necessary to, to make a risk decision?

00:10:25,044 --> 00:10:25,054 [speaker_1]

Mm.

00:10:25,063 --> 00:10:29,384 [speaker_0]

Like, as you mentioned, affected modules or the business impacts.

00:10:29,404 --> 00:10:30,124 [speaker_1]

Mm.

00:10:30,164 --> 00:10:33,334 [speaker_0]

But you al- already mentioned those things, so...

00:10:33,344 --> 00:10:44,633 [speaker_1]

Yeah. I think this also helps-- I mean, if you imagine you're like a risk manager at an organization, they will then talk to, like, executives, um-

00:10:44,644 --> 00:10:44,864 [speaker_0]

Mm

00:10:44,904 --> 00:10:54,384 [speaker_1]

... and the executives, like when they need to make a decision about, like, whether to deploy a system, for example, they will take into account, like-- they, they will get the security audit, but they will also get a bunch of other information.

00:10:54,404 --> 00:10:54,764 [speaker_0]

Mm-hmm.

00:10:54,824 --> 00:11:00,944 [speaker_1]

And sort of if you try to convert your audit into the same unit-

00:11:01,124 --> 00:11:01,354 [speaker_0]

Mm-hmm

00:11:01,384 --> 00:11:03,644 [speaker_1]

... that, that these other information are like-

00:11:03,743 --> 00:11:03,884 [speaker_0]

Yeah

00:11:03,944 --> 00:11:08,124 [speaker_1]

... like, uh, made in. And the other units are often like cost or like-

00:11:08,164 --> 00:11:08,284 [speaker_0]

Yeah

00:11:08,304 --> 00:11:12,764 [speaker_1]

... impact on, [clears throat] um, yeah, on the business, like-

00:11:12,983 --> 00:11:13,144 [speaker_0]

Mm-hmm

00:11:13,344 --> 00:11:14,944 [speaker_1]

... like in the qualitative terms.

00:11:14,983 --> 00:11:15,524 [speaker_0]

Yeah.

00:11:15,624 --> 00:11:19,144 [speaker_1]

Um, I think that helps, rather than just like giving, like, the raw-

00:11:19,644 --> 00:11:19,944 [speaker_0]

Data

00:11:19,954 --> 00:11:20,694 [speaker_1]

... measurements.

00:11:20,694 --> 00:11:54,184 [speaker_0]

Yeah. Mm-hmm. Yeah, perfect. Um, the fourth question is: What responsibility information do you need to clarify risk ownership? Um, so is it helpful to have on the report, like an owner per system or a responsibility matrix, or like escalation roles? Or is that all too much? Or do you want-- do you even want to see the, the risk ownership on the report, like who's responsible for the code or like the code base or the-

00:11:54,284 --> 00:11:54,784 [speaker_1]

Yeah

00:11:54,844 --> 00:11:54,854 [speaker_0]

... the-

00:11:54,864 --> 00:11:56,434 [speaker_1]

Yeah. No, that's very useful.

00:11:56,464 --> 00:11:56,534 [speaker_0]

Yeah.

00:11:56,534 --> 00:12:01,844 [speaker_1]

Yes. Um, again, so there's, like, some standardized frameworks, right, on-

00:12:01,864 --> 00:12:02,044 [speaker_0]

Mm-hmm

00:12:02,544 --> 00:12:10,784 [speaker_1]

... um, what roles people have, uh, like what roles there should be in an, in an organization.

00:12:10,794 --> 00:12:10,794 [speaker_0]

Yep.

00:12:10,844 --> 00:12:22,444 [speaker_1]

And-... sort of, yeah, it's, like, more easily digestible if, if you, like, map, um, like, the specific titles of, of the people in the specific c-company-

00:12:22,514 --> 00:12:22,724 [speaker_0]

Mm-hmm

00:12:23,304 --> 00:12:23,824 [speaker_1]

-to-

00:12:24,184 --> 00:12:24,284 [speaker_0]

Yeah

00:12:24,344 --> 00:12:38,944 [speaker_1]

... to those, like, more generally used terms. So for example, if you're like: Okay, like, the web framework is just like three lines of defense, and if you can say: "Okay, like, um, like, this person is like doing this and that, so they're, like, roughly equivalent to, like, first line of defense-

00:12:38,954 --> 00:12:38,954 [speaker_0]

Mm.

00:12:38,954 --> 00:12:40,894 [speaker_1]

-and then that person is doing that and that."

00:12:40,904 --> 00:12:41,174 [speaker_0]

Mm-hmm.

00:12:41,174 --> 00:12:58,104 [speaker_1]

Um, for example, this helps. I, I think, like, all of this, like, is like... [keyboard clacking] Yeah, like, all of the previous stuff I said is, like, a bit, a bit, uh, sort of hinges on this audit report goes directly to a decision maker who doesn't have context, right?

00:12:58,113 --> 00:12:58,113 [speaker_0]

Yeah.

00:12:58,124 --> 00:13:01,094 [speaker_1]

You could also write an audit report where, like, a security person then-

00:13:01,104 --> 00:13:01,194 [speaker_0]

True

00:13:01,224 --> 00:13:02,704 [speaker_1]

... reviews the audit report and, like-

00:13:02,784 --> 00:13:03,164 [speaker_0]

Yeah

00:13:03,174 --> 00:13:09,764 [speaker_1]

... yeah, gives it to a decision maker, like, makes a recommendation to a decision maker.

[keyboard clacking]

00:13:12,844 --> 00:13:38,784 [speaker_0]

Perfect. Um, so in, in my report, like, the, the whole pipeline thing, the first step the developer has to, like, input is the provenance or the, the origin of the code. And there's, like, a bit of a hiccup because the developer has to be honest, like, stating: "Yeah, I used AI for my code," or, like, "It's totally AI-generated."

00:13:38,794 --> 00:13:40,644 [speaker_1]

Mm-hmm.

00:13:40,654 --> 00:13:50,044 [speaker_0]

Um, so how would you use this provenance that is based on the honesty of the developer in those reports, or would you use it at all?

00:13:50,064 --> 00:13:50,954 [speaker_1]

Mm-hmm.

00:13:50,964 --> 00:14:09,504 [speaker_0]

And if you use it, like, do you have-- Like, what are you- what are the requirements for you to, to have the reliability of this information, basically like... And how do you deal with the uncertainty that the, the developer-

00:14:09,684 --> 00:14:09,774 [speaker_1]

Mm-hmm

00:14:10,384 --> 00:14:17,904 [speaker_0]

... has to be honest, and it's not like a technical evidence that AI was used for the code?

00:14:17,944 --> 00:14:34,584 [speaker_1]

Hmm. Yeah. Um, so I guess the assumption here is that A- A- AI written code, like, introduces some inherent uncertainty about, like, vulnerabilities or so-

00:14:34,604 --> 00:14:34,673 [speaker_0]

Yeah

00:14:34,673 --> 00:14:36,434 [speaker_1]

... because it might just be, like, somewhat like inaccurate.

00:14:36,444 --> 00:14:37,644 [speaker_0]

Exactly.

00:14:37,744 --> 00:15:01,604 [speaker_1]

Yeah. Um, hmm. Yeah. I mean, ideally, part of the audit would be... Or, like, I mean, the audit will partly, well, it will to some extent be about: Okay, do we expect that with this, like, data, uh, like, like, AI-generated code base, um-

00:15:01,624 --> 00:15:01,774 [speaker_0]

Mm-hmm

00:15:02,844 --> 00:15:11,424 [speaker_1]

... that this leads to any, any problems? Um, so I think I would definitely, like, w- like, for the audit, I would de- definitely ask about it.

00:15:11,584 --> 00:15:11,844 [speaker_0]

Mm-hmm.

00:15:11,944 --> 00:15:22,164 [speaker_1]

Um, because I would imagine that that leads to somewhat different, maybe somewhat different testing approaches, but it leads to, like, higher error bars, probably on-

00:15:22,204 --> 00:15:22,324 [speaker_0]

Mm-hmm

00:15:22,344 --> 00:15:36,884 [speaker_1]

... like, the security of the system. Um, and, and then, uh, like, as a decision maker, I don't know whether you need to know it. Like, if you can, like, translate it into, like, some-- For example, if it just, like, has an effect on the uncertainty-

00:15:36,944 --> 00:15:37,204 [speaker_0]

Mm-hmm

00:15:37,224 --> 00:15:51,613 [speaker_1]

... um, then I don't, like, uh, I don't necessarily- I would not necessarily think, like, I would not necessarily need to know. I also kind of expect, I don't know to what extent this is, like, super sensitive for companies to admit, because-

00:15:51,624 --> 00:15:51,824 [speaker_0]

Mm-hmm

00:15:51,834 --> 00:15:54,154 [speaker_1]

... my expectation is just, like, this will just become, like, very common.

00:15:54,164 --> 00:15:57,704 [speaker_0]

Mm-hmm. Yeah. [chuckles] Yeah.

00:15:58,364 --> 00:15:58,434 [speaker_1]

Yeah.

00:15:58,434 --> 00:16:00,704 [speaker_0]

Yeah, good points.

00:16:00,844 --> 00:16:07,953 [speaker_1]

[keyboard clacking] But yeah, I'm not sure. I mean, like, OpenAI and Tropic, and so on, like, they're already-- Like, uh, this is the companies I return there.

00:16:07,964 --> 00:16:08,414 [speaker_0]

[chuckles] Yeah.

00:16:08,504 --> 00:16:09,484 [speaker_1]

Half of our code is written by them.

00:16:09,584 --> 00:16:27,524 [speaker_0]

Yes, for sure. [chuckles] Um, sixth question already: Um, how should a report, um... I think we mentioned this earlier, or you mentioned it: How should your report make its limitations or uncertainties transparent without losing trust? Like, um-

00:16:28,404 --> 00:16:28,414 [speaker_1]

Mm

00:16:28,414 --> 00:16:46,584 [speaker_0]

... maybe al- already known blind spots or tool limitations. Like, would you be upfront with it in the report and, like, say, you know, I don't know, like, disclaimer box, like, "This is auto-generated, and there is very limited human input into the dream or report." Or would you, like, completely leave it out of there, or?

00:16:46,644 --> 00:16:47,884 [speaker_1]

No, I would, uh-

00:16:47,904 --> 00:16:47,914 [speaker_0]

Yeah

00:16:47,914 --> 00:16:48,094 [speaker_1]

... definitely

00:16:48,094 --> 00:16:48,924 [speaker_0]

Definitely.

00:16:48,944 --> 00:17:00,184 [speaker_1]

Put this in. I think... [keyboard clacking] Yeah, so what I like, I mean, generally in research, what I like is, like, I think the limitations section are super important-

00:17:00,204 --> 00:17:00,294 [speaker_0]

Mm

00:17:00,384 --> 00:17:03,694 [speaker_1]

... and actually give a lot of credibility to a report.

00:17:04,564 --> 00:17:04,594 [speaker_0]

Mm.

00:17:04,684 --> 00:17:17,824 [speaker_1]

And I do think, though, that it's, uh, like, it's always good to follow, like, like, every limitation with a, with a brief statement on why this is sort of okay for now or what will be done-

00:17:17,864 --> 00:17:17,874 [speaker_0]

Mm-hmm

00:17:17,874 --> 00:17:18,904 [speaker_1]

... to mitigate it-

00:17:18,924 --> 00:17:19,084 [speaker_0]

Mm-hmm, mm-hmm

00:17:19,384 --> 00:17:26,614 [speaker_1]

... or, um, or just, like, what it means in terms of how this audit report should be used.

00:17:26,804 --> 00:17:26,934 [speaker_0]

Yeah.

00:17:26,964 --> 00:17:32,244 [speaker_1]

Um, so some- some- something like: "Okay, how is this addressed in a, in a way?" Or like-

00:17:32,264 --> 00:17:32,354 [speaker_0]

Yeah

00:17:33,264 --> 00:17:37,134 [speaker_1]

... "Why, why this does not put into question the whole, whole thing?" Um-

00:17:37,224 --> 00:17:38,224 [speaker_0]

Mm-hmm.

00:17:38,244 --> 00:17:44,424 [speaker_1]

Yeah, and then it's actually, it's, it's, it's good, and it gives a very well, so.

00:17:44,504 --> 00:17:52,304 [speaker_0]

All right. Um, then last question: I will show you, like, my, my mock report now-

00:17:52,344 --> 00:17:52,554 [speaker_1]

Mm-hmm

00:17:52,684 --> 00:18:15,744 [speaker_0]

... um, that I mentioned. And when you, when you see it, just tell me, um, like, what's immediately helpful, um, or what is missing, in your opinion, to-- if you were in that role, to make a decision. Like, if you see the report and you have to make a risk decision, um, is it good or is it just-

00:18:15,784 --> 00:18:15,794 [speaker_1]

Mm

00:18:15,794 --> 00:18:22,995 [speaker_0]

... bad?... So that's it. You can just, yeah, use my laptop to scroll around, um, however you would like.

00:18:23,035 --> 00:18:25,196 [speaker_1]

What's those arrows here?

00:18:25,255 --> 00:18:26,916 [speaker_0]

That's, uh, lines of code.

00:18:26,936 --> 00:18:27,446 [speaker_1]

Uh-huh. Okay.

00:18:27,446 --> 00:18:27,856 [speaker_0]

See, yeah?

00:18:27,956 --> 00:18:28,075 [speaker_1]

Maybe-

00:18:28,136 --> 00:18:32,706 [speaker_0]

That's too technical already. [laughing] Yeah.

00:18:32,706 --> 00:18:36,706 [speaker_1]

[laughing] Colors, too. Yeah, so the problem is I don't know what any of these three things here mean.

00:18:36,706 --> 00:18:37,386 [speaker_0]

Okay. Yeah.

00:18:37,396 --> 00:18:44,436 [speaker_1]

So maybe it would be useful to spell them out against, like, if someone uses this regularly, they will-

00:18:44,515 --> 00:18:44,616 [speaker_0]

Yeah

00:18:44,656 --> 00:18:49,596 [speaker_1]

... know. Uh, yeah, this is good. This is, I guess, a percentage-

00:18:49,656 --> 00:18:49,856 [speaker_0]

Mm-hmm

00:18:49,866 --> 00:18:53,436 [speaker_1]

... number. Okay. Yeah, could be good to-

00:18:53,476 --> 00:18:53,795 [speaker_0]

[sniffs]

00:18:53,815 --> 00:19:01,976 [speaker_1]

Make percent. Yeah, so there's a bunch of terms I don't know, but-

00:19:02,035 --> 00:19:02,275 [speaker_0]

Okay

00:19:02,285 --> 00:19:06,616 [speaker_1]

... maybe that's fine. Like, I don't know tickets, um, I don't know SLAs.

00:19:07,196 --> 00:19:11,315 [speaker_0]

Uh, yeah, tickets is basically meant, like, if there is a vulnerability-

00:19:11,336 --> 00:19:11,495 [speaker_1]

Mm-hmm

00:19:11,656 --> 00:19:14,696 [speaker_0]

... then there has to be a ticket assigned to a developer to, like-

00:19:14,775 --> 00:19:14,785 [speaker_1]

Mm

00:19:14,785 --> 00:19:16,336 [speaker_0]

... mitigate or resolve it.

00:19:16,346 --> 00:19:16,346 [speaker_1]

Mm.

00:19:16,376 --> 00:19:21,775 [speaker_0]

Like, in software development, there's every feature is, like, documented in tickets.

00:19:21,815 --> 00:19:21,956 [speaker_1]

Right.

00:19:21,975 --> 00:19:22,305 [speaker_0]

That's-

00:19:22,334 --> 00:19:24,436 [speaker_1]

Right. Yeah, like, if it's, like, a standard term-

00:19:24,596 --> 00:19:24,606 [speaker_0]

Mm

00:19:24,606 --> 00:19:26,436 [speaker_1]

... people, like, in the relevant target audience-

00:19:26,495 --> 00:19:26,856 [speaker_0]

Okay, yeah

00:19:26,866 --> 00:19:30,565 [speaker_1]

... will know, then it's fine. But, like, for a policymaker, they would be like, "I don't know."

00:19:30,565 --> 00:19:30,886 [speaker_0]

I see. Yeah.

00:19:30,995 --> 00:19:31,866 [speaker_1]

Like, for a risk management-

00:19:31,876 --> 00:19:31,906 [speaker_0]

Mm-hmm

00:19:31,906 --> 00:19:35,995 [speaker_1]

... security risk management, they imagine so.

00:19:36,055 --> 00:20:01,716 [speaker_0]

I could imagine that this is also, like, way too technical.

00:20:01,735 --> 00:20:02,156 [speaker_1]

[chuckles] Yeah.

00:20:02,176 --> 00:20:02,815 [speaker_0]

Right? Yeah.

00:20:02,876 --> 00:20:29,775 [speaker_1]

Yeah, I recognize the n- the RMF, uh, sections, but otherwise... Yeah. Um-

00:20:30,116 --> 00:20:30,186 [speaker_0]

Yeah, but it-

00:20:30,196 --> 00:20:37,295 [speaker_1]

Maybe it would be sort to have some... I mean, I guess high is, like, sort of high priority. Maybe it would be useful to give an explanation of high.

00:20:37,376 --> 00:20:41,596 [speaker_0]

Uh, yeah, I, uh, I think that's, um, about the severity of the-

00:20:41,656 --> 00:20:41,666 [speaker_1]

Mm

00:20:41,666 --> 00:20:42,676 [speaker_0]

... of the findings. Like-

00:20:42,696 --> 00:20:42,706 [speaker_1]

Mm

00:20:42,706 --> 00:20:46,176 [speaker_0]

... this SQL injection is, like, a, a high finding.

00:20:46,196 --> 00:20:48,476 [speaker_1]

Mm.

00:20:48,495 --> 00:20:52,896 [speaker_0]

But yeah, the, the, those, uh, finding clusters are way too technical-

00:20:52,956 --> 00:20:53,146 [speaker_1]

Yes, yes

00:20:53,146 --> 00:20:54,755 [speaker_0]

... in general, I think. Yeah.

00:20:54,856 --> 00:21:12,315 [speaker_1]

Yes. Um... Yeah, so... Yeah, so this is a bit, like, it is too technical for me-

00:21:12,335 --> 00:21:12,466 [speaker_0]

Mm-hmm

00:21:12,466 --> 00:21:14,696 [speaker_1]

... to, like, make sense of it.

00:21:14,716 --> 00:21:15,096 [speaker_0]

Mm-hmm.

00:21:15,235 --> 00:21:24,416 [speaker_1]

Um, like, personally, for me, it should-- for this to be more useful would be, like, if there was just, like, two or three lines of plain text here that said, like-

00:21:24,456 --> 00:21:25,576 [speaker_0]

At the recommendations?

00:21:25,616 --> 00:21:25,876 [speaker_1]

Yeah.

00:21:25,896 --> 00:21:26,055 [speaker_0]

Yeah.

00:21:26,064 --> 00:21:29,596 [speaker_1]

Before the... Or, like, a summary or something, which said, like, here essentially.

00:21:29,606 --> 00:21:30,765 [speaker_0]

Like, also the executive summary.

00:21:30,916 --> 00:21:30,926 [speaker_1]

Yeah.

00:21:30,936 --> 00:21:33,775 [speaker_0]

Like, not only just plain numbers, also, like-

00:21:33,835 --> 00:21:33,956 [speaker_1]

Yeah

00:21:33,995 --> 00:21:34,936 [speaker_0]

... the text. Mm-hmm.

00:21:34,956 --> 00:21:43,936 [speaker_1]

Yeah. So which would be essentially be like: "This, um, audit found three types of-

00:21:43,956 --> 00:21:43,966 [speaker_0]

Mm

00:21:43,966 --> 00:21:53,515 [speaker_1]

... um, issues in the system. We recommend resolve-- Like, one of them as high severity, we recommend at least resolving-

00:21:53,555 --> 00:21:54,255 [speaker_0]

Mm-hmm. Mm-hmm

00:21:55,255 --> 00:21:58,495 [speaker_1]

... um, this high issue before implementing the system."

00:21:58,515 --> 00:21:59,985 [speaker_0]

Yeah, great. Mm-hmm.

00:22:00,116 --> 00:22:10,356 [speaker_1]

Um, "With that issue resolved, the system can be deployed and will be sort of, will persist-

00:22:10,436 --> 00:22:10,616 [speaker_0]

Mm

00:22:10,696 --> 00:22:11,545 [speaker_1]

... threat actor X."

00:22:11,555 --> 00:22:14,035 [speaker_0]

Or can be used safely or whatever. Yeah.

00:22:14,045 --> 00:22:14,045 [speaker_1]

Yeah, can be used safely-

00:22:14,116 --> 00:22:14,396 [speaker_0]

Mm

00:22:14,495 --> 00:22:15,446 [speaker_1]

... threat actor X."

00:22:15,636 --> 00:22:16,064 [speaker_0]

Yeah, that's right.

00:22:16,076 --> 00:22:17,275 [speaker_1]

Or just, can you just take the-

00:22:17,295 --> 00:22:18,396 [speaker_0]

Mm.

00:22:18,476 --> 00:22:19,976 [speaker_1]

Yeah. Something like that.

00:22:20,015 --> 00:22:20,525 [speaker_0]

Cool.

00:22:20,576 --> 00:22:25,476 [speaker_1]

Yeah. "And then we also recommend resolving the two other medium issues."

00:22:25,495 --> 00:22:26,295 [speaker_0]

Mm.

00:22:26,335 --> 00:22:32,576 [speaker_1]

And then maybe, maybe even, like, a thing of... Maybe actually a thing of, like, how much effort, like, how much expected effort it would be to resolve the issues.

00:22:32,656 --> 00:22:34,044 [speaker_0]

Oh, yeah. Mm-hmm.

00:22:34,196 --> 00:22:44,076 [speaker_1]

Um, [clears throat] yeah, some plain text.

00:22:44,085 --> 00:22:44,126 [speaker_0]

Mm-hmm.

00:22:44,126 --> 00:22:46,916 [speaker_1]

But maybe for technical persons, which would be very like they-

00:22:46,936 --> 00:22:50,476 [speaker_0]

Yeah, but I think most of the, like, risk decision-

00:22:50,535 --> 00:22:50,795 [speaker_1]

Yeah

00:22:50,855 --> 00:22:56,416 [speaker_0]

... takers, um, are not that technically averse.

00:22:56,436 --> 00:22:56,446 [speaker_1]

Yeah.

00:22:56,495 --> 00:22:57,255 [speaker_0]

So-

00:22:57,295 --> 00:22:57,416 [speaker_1]

Yeah

00:22:57,616 --> 00:23:01,235 [speaker_0]

... that's a good point. Like, I'm a heavy technical person, so for me, it's like-

00:23:01,255 --> 00:23:01,295 [speaker_1]

[chuckles]

00:23:01,306 --> 00:23:02,096 [speaker_0]

... where are the numbers?

00:23:02,105 --> 00:23:02,105 [speaker_1]

Mm-hmm. Mm-hmm.

00:23:02,116 --> 00:23:06,735 [speaker_0]

Like, uh, I don't wanna read, like, a whole essay. Um-

00:23:07,176 --> 00:23:08,535 [speaker_1]

Yes.

00:23:08,576 --> 00:23:17,716 [speaker_0]

But I guess you're right, so. Um, yeah, that's great. That's it. Thank you so much, uh-

00:23:17,726 --> 00:23:17,726 [speaker_1]

Yeah

00:23:17,726 --> 00:23:19,515 [speaker_0]

... for taking the time.

00:23:19,535 --> 00:23:19,755 [speaker_1]

And you were welcome.